

PARMANA

What an AI agent may do, and proof of what it did

Policy-checked actions, signed human approval, and records anyone can verify offline

Pavan Dev Singh Charak · Parmana Systems · October 2026

THE PROBLEM

An agent that can act turns a model error into an action

Replit, July 2025

Told not to change anything without approval, an agent deleted a production database during a code freeze.

Amazon Q, July 2025

A prompt added to a coding extension told the assistant to delete files and cloud resources.

In both, the credentials the agent held decided what it could do. "Ask first" lived only in the conversation.

WHAT EACH TOOL ANSWERS

Existing controls answer narrower questions

Tool	The question it answers
IAM, OAuth scopes	May this caller use this API, for a long time?
API gateway	May this request pass, and how fast?
LLM guardrails	Does this text look harmful?
Parmana	May this exact action run now, did a named person approve it, and can anyone verify what ran?

HOW IT WORKS

Every action takes the same path

1 Propose

The agent submits an action, its target and parameters

2 Policy

Versioned rules; no matching rule refuses

3 Approve

A registered person signs this exact action

4 Release

The gateway re-checks, then calls the system

5 Record

A signed record of what ran, or of the refusal

The agent never holds the credentials for the systems it acts on.

SIGNED HUMAN APPROVAL

A person approves one action, not a role

Bound

to the action, the resource and the amount

Signed

Ed25519, by a registered, unrevoked approver

Single use

spent once, across every server instance

Expiring

15 minutes by default, 24 hours at most

A policy that could approve without a signed approval fails to load. What the agent declares can only refuse, never approve.

One place releases actions, and it checks again

Before every release

- Signature on the authorization
- Expiry, to the instant
- Hash of the exact request
- Policy is the approved current version
- Nonce: used once, in a shared store

Credentials

- Held by the gateway, never by the agent
- Resolved per call, never stored as state
- Shown in records only as a fingerprint
- No other code path reaches a connector

RECORDS

Evidence you can check without trusting us

- A signed intent before release; nothing runs without one
- A signed record of every action and every refusal
- Ed25519, optionally with ML-DSA-65
- Verify offline with only the public key

amount: 100 → valid

amount: 100000 → hash mismatch

Change any signed field and verification fails.

A valid result proves the record is unchanged and signed by the key holder, not that the holder was honest.

The agent is assumed hostile; the assumptions are written down

Defended against

- Anyone on the network
- A caller with a valid key controlling the whole request, including an injected agent
- A captured authorization or used approval
- One governance credential
- Someone who can alter stored records

Assumed, not defended

- Signing keys are not compromised
- Approvers hold their own keys
- Maker and checker are two people
- The database is not attacker writable
- Policies are written correctly

EVIDENCE

16 attacks you can run yourself

Attack	Attack
Replay a used authorization	Rely on facts that changed after approval
Forge or alter an authorization	Obtain a connector's credentials
Expired authorization or revoked key	Reach a connector without the gateway
Act without a signed approval	Act outside a caller's scope
Forge or misuse an approval	Change a policy without a second person
Declare one action, execute another	Alter a signed record
Be judged by a weaker policy	Run one transaction twice by racing
Execute under an outdated policy	Write a policy outside its directory

npm run evaluate -- EV-04

TESTING THE TESTS

Mutation testing of the security-critical code

94.0%

envelope verifier
from 89.7%

93.9%

approval
from 77.7%

96.0%

policy
from 50.3%

83.6%

gateway
from 67.6%

85.0%

crypto
from 65.4%

A surviving mutant is a test that would not notice a bug. Several led to real fixes, not only new tests.

WHAT THE CHECKS FOUND

Found, fixed, and published

Found by	What it was
Mutation	An edited execution with its chain signature removed passed the chain check (G-89)
Fuzzing	A malformed request crashed validation instead of returning a clear 400 (G-87)
Fuzzing	A malformed signatures field made the offline verifier throw (G-91)
CodeQL	A policy named ".." could read and write outside its directory (G-88, advisory GHSA-hp43-9p54-wqp9)

Each fix has a test that failed before it. Open gaps are listed next to the claims.

LIMITS

What Parmana does not do

Read text

No prompt injection or harmful output detection. Use a guardrail.

Cover other routes

Only actions routed through it. An agent with other credentials acts outside it.

Fix every parameter

An approval fixes action, resource and amount, not a message's text.

Replace judgment

A person can be persuaded to approve. Approvers are not yet scoped per action (G-50).

Bound what an agent can make happen. Leave evidence anyone can check.

docs.parmanasystems.com

github.com/pavancharak/parmana

Claims, attacks and open gaps are public. Questions in GitHub Discussions.